

Dynamic Analysis & Sandboxing

Why Dynamic

Static tells you WHAT it might do. Dynamic shows you WHAT IT ACTUALLY DOES – the C2 domain it dials, the files it touches, the persistence it plants.

The Safe Sandbox Setup

Rules:

- Isolated VM, no shared folders (or read-only snapshots)
- Host-only/isolated network – let it talk to a *fake* server you control
- Snapshot before + revert after each run
- No internet to the real world (firewall the VM)
- Never analyze on your production machine, ever.

Observing Behavior

Run the sample, then capture:

Artifact	Tool	Signal
Processes	Procmon, procps	What children spawn?
File changes	Procmon	What did it write?
Registry	Procmon	Persistence keys?
Network	Wireshark/tshark	C2 beacon pattern/domain
API calls	Python <code>ntapi</code> /Frida	What syscalls?

The Fake-C2 Trick

Instead of letting malware hit the hostile internet, route it to **you**:

```
# fake webserver that logs EVERY request
python3 -m http.server 80 &
# or spin up a fake responder that logs DNS/HTTP
```

Observe what the malware asks for – its queries reveal its C2 protocol even to you.

Understanding Behavior Through Procmon

Process Monitor (Windows) shows:

- Process tree (who spawned whom)
- File writes (what/where)
- Registry ops (persistence, config)
- Network ops

The **patterns** matter more than individual events: *downloader* → *drops payload* → *registers autorun* → *beacons out* → *theft*. That's the full chain you document.

Anti-Analysis Evasion (the malware fights back)

- Anti-VM** – checks for VirtualBox/VMware artifacts (exits if detected)
- Sandbox detection** – sleeps, checks process names, mouse activity
- Time-based** – delayed execution to outlast the sandbox
- Packed** – encrypted until runtime

How analysts win: multiple sandboxes, timeout-bypass tricks (UNTRUST the clock), memory dumping before/after unpacking.

Communicate Your Findings

A malware analysis report format:

- Summary (2-3 sentences)
- Key indicators (hash, family, C2)
- Behavioral findings (processes, files, network, persistence)

Detection guidance (YARA, EDR rules)

IOCs list (IPs, domains, hashes)

← Static Malware Analysis

Module complete ✓